

Security Fundamentals · Section 5

Common Attacks: Phishing, Malware, and More

By TOUCH DEN · November 11, 2026

Contents

What You Will Learn 1

Before You Start 1

1. How Most Attacks Actually Start 1

2. Phishing and Social Engineering 2

3. Malware: Viruses, Worms, Trojans, and Ransomware 3

4. Password Attacks 3

5. Attacks on Web and Network Services 4

6. Denial of Service 4

7. Man-in-the-Middle 5

8. The Attack Lifecycle 5

Common Mistakes 5

Summary 6

Check Your Understanding 6

Practice 7

What You Will Learn

- *How most real attacks actually begin.*
- *Phishing and social engineering: attacking people, not machines.*
- *The main kinds of malware, and how they differ.*
- *How passwords are attacked.*
- *Attacks on web and network services, at a high level.*
- *Denial-of-service and man-in-the-middle attacks.*
- *The attack lifecycle: the stages most attacks move through.*

Before You Start

Read lessons 1 to 4. This lesson names the attacks the earlier lessons kept referring to. It is a map, not a manual: each attack is explained so you can recognize and defend against it, and each is studied in depth, safely and legally, in a later course. Remember the one rule: these are only ever tried on systems you own or have written permission to test. No programming is needed.

---

1. How Most Attacks Actually Start

Attacks are not usually a single dramatic break-in. They start small and quiet, most often in one of three ways:

1. ***A person is tricked** into clicking, opening, or telling (phishing and social engineering).*
2. ***A weakness is exploited** in software that is exposed to the internet and not updated.*
3. ***A stolen or guessed password** is used to simply log in.*

Study after study of real breaches finds the same thing: the large majority begin with one of these three, and very often with the first. The attacker does not need to be a genius; they need one person to click, or one unpatched server, or one reused password. This is good news for defenders, because it means a few basic defenses, aimed at these three doors, stop most attacks.

The rest of this lesson walks through the common attacks, grouped by what they target: people, machines, passwords, services, and the network.

2. Phishing and Social Engineering

Social engineering *is attacking the person instead of the computer: tricking someone into doing something that helps the attacker. It works because it is far easier to fool a human than to break strong encryption.*

Phishing *is the most common form: a fake message, usually email, that pretends to be from someone you trust, to make you click a link, open an attachment, or hand over a password. Variants have their own names:*

- ***Spear phishing:*** *a targeted phish, personalized for one person or company, often after research.*
- ***Whaling:*** *spear phishing aimed at an important person, like a CEO.*
- ***Smishing*** *and* ***vishing:*** *the same idea by SMS text and by voice call.*
- ***Business email compromise (BEC):*** *posing as a boss or supplier to get an employee to pay a fake invoice or change bank details. It steals enormous sums with no malware at all.*

How to recognize a phish: a sense of urgency ("act now or your account closes"), a request for a password or payment, a slightly wrong sender address, a link that does not go where it claims, and spelling or tone that is a little off.

Defenses: *training and healthy suspicion; checking the real sender address; never acting on urgency without verifying through another channel; email filtering; and multi-factor authentication, so a stolen password alone is not enough. The Social Engineering course covers this in depth, including running authorized phishing tests.*

3. Malware: Viruses, Worms, Trojans, and Ransomware

Malware is any software written to do harm. The word covers several kinds, grouped by how they spread and what they do:

Type	How it behaves
Virus	Attaches to a file or program; spreads when that file is run or shared by a person
Worm	Spreads by itself across a network, with no human action, by exploiting weaknesses
Trojan	Pretends to be something useful (a free game, a cracked app) so you install it yourself
Ransomware	Locks or encrypts your files and demands payment
Spyware	Secretly watches you: keystrokes, screens, passwords
Rootkit	Hides deep in the system to avoid detection and keep control
Botnet (bot)	Turns your machine into one of thousands the attacker controls remotely

These categories overlap: one real piece of malware can be a trojan that installs spyware and later ransomware. What matters for defense is less the label than the behavior.

Defenses: keep software updated (worms spread through known, unpatched holes); do not run untrusted programs or attachments; use anti-malware tools; limit accounts to least privilege so malware cannot reach everything; and keep offline backups so ransomware cannot destroy your only copy. The Malware Analysis course studies how malware works and how to analyze it safely.

4. Password Attacks

Because passwords guard so much, attacking them is a whole category. The main methods:

- **Guessing / brute force:** trying many passwords until one works. Automated tools try millions.
- **Dictionary attack:** trying common passwords and real words first, because people pick them.
- **Credential stuffing:** taking username-and-password pairs leaked from one breached site and trying them on others, because people reuse passwords. This is one of the most effective attacks today.
- **Password spraying:** trying one or two very common passwords against many accounts, to avoid locking any single one.
- **Phishing for passwords:** simply asking, via a fake login page.

Attackers rarely guess against a live login screen, which is slow and noisy. More often they steal a file of stored passwords and attack it offline. This is why how passwords are stored matters so much: they should be protected with slow ***password hashing****, never stored as plain text. Lesson 6 is devoted to passwords and authentication, and the Cryptography course explains hashing fully.*

Defenses: *long, unique passwords (a password manager makes this easy); multi-factor authentication, which defeats stolen passwords; and, on the defender's side, storing passwords with strong, slow hashing and watching for spraying and stuffing.*

5. Attacks on Web and Network Services

Any service exposed to the internet, a website, an app's back end, a mail server, is a door an attacker can knock on. The most common web attacks (studied hands-on in the Web Application Security course) include:

- ***Injection, such as SQL injection:*** *sending crafted input that the server mistakes for a command, letting an attacker read or change the database.*
- ***Cross-site scripting (XSS):*** *sneaking malicious code into a web page so it runs in other users' browsers.*
- ***Broken access control:*** *reaching data or actions you should not be allowed to, such as viewing another user's account by changing a number in the address.*

The common thread is ***trusting input that should not be trusted****, the same lesson as "never trust the client" from the mobile world. The defense, broadly, is to treat all input as untrusted, validate it, and make the server, not the user, enforce the rules. The OWASP Top 10 (lesson 10, and the web course) is the standard list of these risks.*

6. Denial of Service

A ***denial-of-service (DoS)*** *attack does not steal or change data; it attacks* ***availability****, by overwhelming a system so real users cannot use it. The usual method is a flood: far more requests than the system can handle, so it slows to a crawl or falls over.*

A ***distributed denial-of-service (DDoS)*** *attack sends the flood from many machines at once, often a* ***botnet*** *of thousands of infected devices around the world. This makes it bigger and much harder to block, since the traffic comes from everywhere.*

Defenses: *extra capacity; filtering and rate-limiting; and specialized anti-DDoS services that absorb and scrub the flood before it reaches you. For most small organizations, a hosting provider or a content-delivery network handles the worst of it.*

7. Man-in-the-Middle

A **man-in-the-middle (MITM)** attack puts the attacker secretly between you and who you think you are talking to, so they can read or change the messages passing through. A classic setting is an open public Wi-Fi network, where an attacker on the same network can position themselves in the path of your traffic.

If the traffic is unencrypted, the attacker reads everything, and can alter it. This is exactly why **HTTPS** (the padlock, encrypted web traffic) matters: it encrypts the connection so a man in the middle sees only scrambled data, and it checks that you are really connected to the right site, not an impostor. The Networking and Cryptography courses explain how this protection works.

Defenses: use encrypted connections everywhere (HTTPS, a VPN on untrusted Wi-Fi); heed browser certificate warnings instead of clicking past them; and, for apps, verify the server's identity properly.

8. The Attack Lifecycle

Most serious attacks are not one action but a sequence of stages. Security people use models of this sequence, such as the **Cyber Kill Chain** and the more detailed **MITRE ATT&CK** (lesson 10), to understand and interrupt attacks. A simplified lifecycle:

1. **Reconnaissance:** research the target, find email addresses, systems, and weaknesses.
2. **Initial access:** get in, usually via phishing, an exposed weakness, or a stolen password.
3. **Establish foothold:** install something to keep access, even if the first way in closes.
4. **Escalate privileges:** go from a normal account to an administrator (the Pentest courses cover this).
5. **Move laterally:** spread from the first machine to more valuable ones.
6. **Act on the objective:** steal data, deploy ransomware, commit fraud, whatever the goal was.

Why this matters: the attacker must succeed at **every** stage, but the defender only has to stop **one**. This is defense in depth again (lesson 8). Catch the phish and you stop stage 2. Apply least privilege and you block stage 4. Monitor the network and you spot stage 5. Keep offline backups and you blunt stage 6. Every layer is a chance to break the chain.

Common Mistakes

1. Thinking attacks are high-tech wizardry. Most start with a tricked person, an unpatched system, or a stolen password. Defend those three doors first.

2. Judging a phish by spelling alone. *Modern phishing can be flawless. Rely on verifying the sender and the request through another channel, not just on typos.*

3. Treating all malware as "a virus". *Worms spread on their own; trojans trick you into installing them; ransomware extorts you. The defenses differ, and behavior matters more than the label.*

4. Reusing passwords. *Credential stuffing exists precisely because people reuse passwords. One breached site then unlocks all the others.*

5. Trusting open Wi-Fi. *Without encryption, a man in the middle reads everything. Use HTTPS and a VPN on untrusted networks.*

6. Thinking you must stop every stage. *You don't. The attacker must win every stage; you only need to break the chain once. That is the power of layers.*

Summary

Attack	Targets	Core defense
Phishing / social engineering	People	Training, verify, MFA, email filtering
Malware (virus, worm, trojan, ransomware)	Machines	Updates, least privilege, anti-malware, offline backups
Password attacks	Credentials	Unique passwords, MFA, strong hashing on the server
Web/network service attacks	Services	Treat input as untrusted; server enforces rules
Denial of service (DoS/DDoS)	Availability	Capacity, filtering, anti-DDoS services
Man-in-the-middle	Traffic	Encryption (HTTPS/VPN); heed certificate warnings
Attack lifecycle	All stages	Defense in depth: break the chain at any stage

Check Your Understanding

1. What are the three most common ways attacks start?
2. What is the difference between phishing and spear phishing?
3. How does a worm differ from a virus?
4. What is credential stuffing, and which bad habit makes it work?
5. What does a denial-of-service attack target, and how does DDoS differ from DoS?
6. Why does HTTPS defend against a man-in-the-middle attack on open Wi-Fi?

7. *In the attack lifecycle, why is it said that the defender has the advantage?*

Answers

1. *A person tricked (phishing/social engineering); a software weakness exploited on an exposed, unpatched system; and a stolen or guessed password used to log in.*
2. *Phishing is a generic fake message sent widely; spear phishing is targeted and personalized for one person or company, often after research.*
3. *A virus attaches to a file and spreads when a person runs or shares it; a worm spreads by itself across a network with no human action, by exploiting weaknesses.*
4. *Taking username/password pairs leaked from one site and trying them on others. It works because people reuse the same password across sites.*
5. *Availability: it overwhelms a system so real users cannot use it. DDoS sends the flood from many machines at once (often a botnet), making it bigger and harder to block than a single-source DoS.*
6. *HTTPS encrypts the connection, so a man in the middle sees only scrambled data, and it verifies the site's identity, so you are not fooled by an impostor.*
7. *Because the attacker must succeed at every stage of the lifecycle, while the defender only has to stop one stage to break the chain.*

Practice

For each of the three common starting points of an attack, name one defense a small business could put in place this week.

1. *A person being tricked (phishing).*
2. *An exposed, unpatched system.*
3. *A stolen or reused password.*

Then pick one attack from this lesson and describe, in two or three sentences, how you would explain it to a non-technical shop owner, and the single most important thing they should do about it.

A Worked Example

1. *Phishing: a 30-minute staff talk on spotting urgent, payment-related emails, plus turning on the email provider's spam filtering.*
2. *Unpatched system: turn on automatic updates for the computers and the website software.*
3. *Stolen/reused password: turn on multi-factor authentication for email and banking, and give staff a password manager.*

Chosen attack, ransomware: "A criminal locks all your files and demands money. Even if you'd rather not pay, the safest protection is a backup made every night and kept disconnected from the computer, so you can restore everything and ignore the demand. Set that up first."

Course mark icon from Material Symbols by Google, Apache License 2.0. NIST, CIS, ISO, OWASP, and MITRE ATT&CK are the trademarks of their respective owners, used here only to refer to their published work.